

PROJECT: USABLE KEY MANAGEMENT (PART 2)

Throughout the semester, you have been using TLS client authentication to log into the passoff server. In this project, you will be reflecting on that experience. You will also get a chance to experience what is necessary to sync client certificates between multiple machines.

Requirements

In this project, you will access the pass-off server from a new device you haven't used to access the server previously. More specifically:

1. If you have been using a personal computer (i.e., not [REDACTED] machine) to complete the projects, you will need to access the pass-off server using a [REDACTED] machine; **OR**
2. If you have been using a [REDACTED] machine to complete the project, you will need to use a personal computer (i.e., not [REDACTED] machine) to access the pass-off server.

Once you have access to the pass-off server on the new machine, you will use this pass-off website [anonymized institutional site] to verify that you are accessing the pass-off server from a new machine. Next, you will write a report describing your experiences. You will also reflect on your experience using TLS client authentication throughout the semester. Finally, you will complete several thought problems regarding the security of TLS client authentication. The report should have the following contents:

Section 1—Multi-device TLS client authentication

1. How long did it take you to complete this project?
2. What steps did you take to complete the project?
 - Also, include details about anything you attempted that ultimately did not work.
 - *Include screenshots if you think that would be helpful.*
3. Describe what information sources you used and how helpful (or unhelpful) they were.
4. To complete this project, you could either synchronize your existing certificate to the new machine or get a new certificate issued for that machine. Why did you choose the approach that you ultimately used?
5. Answer the after-scenario questionnaire (ASQ) by indicating how much you agree with the following statements on a scale of 1 (strongly disagree) to 7 (strongly agree).
 - Overall, I am satisfied with the ease of setting up TLS client authentication on a second device.
 - Overall, I am satisfied with the amount of time it took to set up TLS client authentication on a second device.

- Overall, I am satisfied with the support information (online help, messages, documentation) I found when setting up TLS client authentication on a second device.
6. Answer the following questions:
 - What were the easiest one or two steps in setting up TLS client authentication on a second device? Why were they the easiest?
 - What were the hardest one or two steps in setting up TLS client authentication on a second device? Why were they the hardest?
 - What would you change about the process for setting up TLS client authentication on a second device?
 7. Provide any other feedback you have about the project or setting up client authentication on a second device.

Section 2—Semester-long reflection

For this section, please reflect on your experience using TLS client authentication to access the pass-off server during the semester.

1. What browser did you use when accessing the pass-off server? What version is it currently running?
2. What steps did you take to authenticate using TLS client authentication when accessing the pass-off server?
3. How did you manage your signed certificate file and private key throughout this semester?
 - If you had to regenerate one or both of these items, please describe your experience doing so.
4. Answer the system usability scale (SUS) questions by indicating how much you agree with the following statements on a scale of 1 (strongly agree) to 5 (strongly disagree). **Note that this scale is different than the previous scale.**
 - I think that I would have no problem using TLS client authentication frequently.
 - I found TLS client authentication unnecessarily complex.
 - I thought that TLS client authentication was easy.
 - I think that I would need the support of a technical support staff to use TLS client authentication in the future.
 - I found the various functions for TLS client authentication to be well-integrated.
 - I thought there was too much inconsistency in TLS client authentication.
 - I would imagine that most people would learn to use TLS client authentication very quickly.
 - I found TLS client authentication to be very cumbersome.
 - I felt very confident using TLS client authentication.
 - I needed to learn a lot of things before I could get going with TLS client authentication.
5. Answer the following questions:

- What was the easiest one to three things about using TLS client authentication? Why were they the easiest?
 - What were the hardest one to three things about using TLS client authentication? Why were they the hardest?
 - What would you change about using TLS client authentication on a second device?
6. How did the usability of setting up TLS client authentication compare to the usability of using TLS client authentication throughout the semester?
 7. Provide any other feedback you have about the project or TLS client authentication on a second device.

Section 3—Thought exercises

In this section, you complete several thought exercises. You will receive full credit for whatever you put down. I'm not looking for you to get the "right" answer, but rather for you to share your thoughts based on what you've learned this semester and your experiences using TLS client authentication.

- Are there any security benefits or drawbacks to using TLS client authentication as compared to password-based authentication? If so, what are they?
- To use TLS client authentication from two devices, you could either synchronize your existing certificate to the new machine or get a new certificate issued for that machine. Each of these approaches has different potential security implications. What do you think the security benefits or drawbacks of each approach are?
- If you were to **lose** your TLS client authentication signed certificate, but not your private key, what would you need to do to regain access to the pass-off server? Are there any security concerns with your proposed workflow? If so, how could they be addressed (*you can answer that you don't know*)?
- If you were to **lose** your TLS client authentication private key, what would you need to do to regain access to the pass-off server? Are there any security concerns with your proposed workflow? If so, how could they be addressed (*you can answer that you don't know*)?
- If you were to have your TLS client authentication private key **stolen**, what would you need to do to regain access to the pass-off server? Are there any security concerns with your proposed workflow? If so, how could they be addressed (*you can answer that you don't know*)?
- Suppose that the certificate you received this semester gave you access to a secure database containing your assignments and labs. Suppose this database has a lateral movement vulnerability that an adversary, Mallory, has identified allowing her to edit grades as the admin user. Mallory's goal is to intercept a student's certificate which would allow her to impersonate that user and gain access to the database where she can exploit this vulnerability. How could the CA and/or pass-off server identify that a certificate has been stolen? In addition, what steps should the CA take to

ensure that this certificate cannot be used?

Getting Started and Getting Help

As the purpose of this project is to give you experience with a real-world cryptosystem, neither the instructor nor the TAs will tell you how to complete this task. **However, you are free to use any online information source you want.** You are also free to use whatever tools you wish to complete this project.

[REDACTED] lab schedule

To complete this project, you will need to access the browser on a [REDACTED] machine. While this can be done over SSH with X forwarding, for most students, it will be easier to complete this project physically at a [REDACTED] machine. Below, you can find the schedule for the [REDACTED] labs. Use this to find a time when the lab is free to complete the first part of the project.

Grading Rubric

- 10 points for completing the first part of the report.
- 20 points for completing the second part of the report.
- 20 points for completing the third part of the report.

Throughout, the report should be well-written, answering the questions listed in the requirements section. Also, if you do not setup TLS client authentication on a second machine, at most you can receive half points for the report.

Submission

Submit your written report as a PDF file to Canvas.